

Governing Generative AI and AI Agents

WHY THIS MODULE MATTERS

Generative AI and autonomous agents break some of the assumptions the rest of this course relies on. This module gives you a governance lens built specifically for large language models, AI agents and the risks they introduce.

8.1 Why Generative AI Needs Its Own Governance Lens

Everything covered so far in this course applies to generative AI — large language models (LLMs) such as those behind chatbots and drafting tools, and the AI agents increasingly built on top of them. But generative AI also breaks some assumptions the rest of this course relies on. A traditional model produces a score or a classification that a human then acts on. A generative model produces open-ended text, code or decisions — and an AI agent can act on its own output directly, sending an email, editing a record or making a purchase without a person in between. Governance built only for scoring models will miss the risks that come from a system that can write, and increasingly act, in ways its own developers cannot fully predict in advance.

8.2 The Model Lifecycle

Generative AI systems move through a lifecycle distinct from a conventional model, and each stage needs its own governance checkpoint rather than a single review at the end.

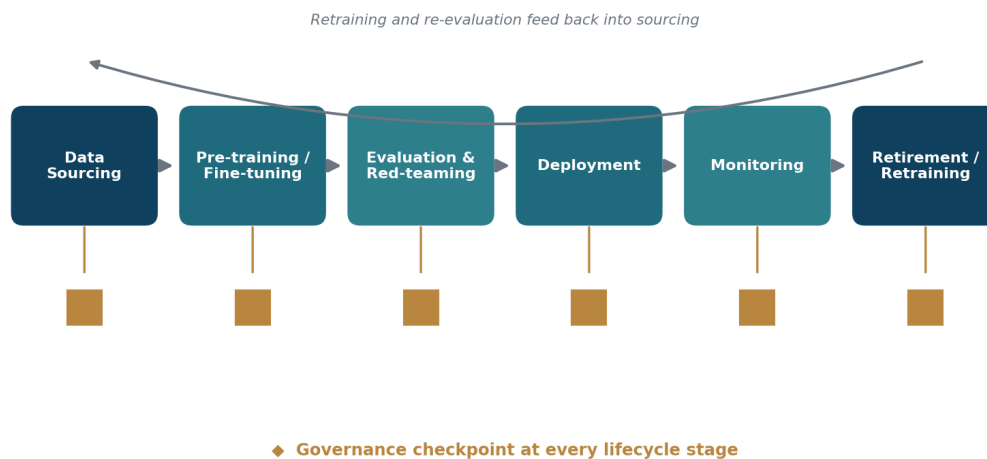


Figure 8.1 — The generative AI model lifecycle, with a governance checkpoint at every stage.

- **Data sourcing** — what data trains or fine-tunes the model, whether it was lawfully obtained, and whether it contains personal or copyrighted material.
- **Pre-training and fine-tuning** — adapting a base model to an organisation's own data and use case, which can reintroduce the bias and data-quality issues covered in Module 3.
- **Evaluation and red-teaming** — deliberately trying to make the system fail or misbehave before real users can, including attempts to extract training data or bypass safety instructions.

- **Deployment** — launching with defined limits on what the system, or any agent built on it, is allowed to do without human sign-off.
- **Monitoring** — ongoing review of real outputs, since generative systems can degrade or be manipulated in ways a one-off test will not catch.
- **Retirement or retraining** — feeding what monitoring finds back into the next version, rather than letting a known issue persist indefinitely.

8.3 LLM-Specific Risks

- **Hallucination** — a model generating fluent, confident, and factually wrong output, with no built-in signal to the user that it might be wrong.
- **Data leakage through prompts** — information typed into a prompt can be retained, logged, or in some configurations used to improve the underlying model, meaning confidential information pasted into a public tool may not stay confidential.
- **Training data provenance and copyright** — outputs can closely resemble copyrighted source material the model was trained on, creating legal exposure that is still actively being tested in courts.
- **Shadow AI** — staff using unsanctioned generative AI tools with company or client data because an approved alternative is slower or does not exist.

CASE STUDY — THE SAMSUNG CHATGPT DATA LEAK

In 2023, engineers at Samsung's semiconductor division were reported to have pasted confidential source code and internal meeting notes into ChatGPT on at least three occasions, seeking help debugging and summarising material. Because that data left the company's own systems and entered a third-party tool outside its control, Samsung had no way to guarantee the confidential material would not be retained or exposed elsewhere.

The company responded by restricting staff use of external generative AI tools on company devices. No system failed technically — the tools worked exactly as designed. The failure was organisational: no policy existed telling staff what was, and was not, acceptable to paste into a public AI tool, and no approved internal alternative had been provided.

8.4 AI Agents and Autonomous Action

An AI agent extends a language model with the ability to take actions — browsing the web, sending messages, calling other software, or executing a purchase — rather than only producing text for a human to act on. This is a meaningful governance escalation: a hallucinated email draft is a nuisance a human can catch before sending, but a hallucinated instruction an agent acts on autonomously can already have happened by the time anyone notices.

- **Human-in-the-loop checkpoints** — defining which actions an agent may take automatically, and which require explicit human approval first, calibrated to the consequences of getting it wrong.

- **Spend and action limits** — hard technical limits on what an agent can commit to or purchase, independent of what its instructions tell it to do.
- **Audit trails** — a complete, tamper-resistant log of what an agent was asked to do and what it actually did, since agent behaviour can diverge from its instructions in ways that are hard to reconstruct after the fact.

8.5 Prompt Security

Prompt injection is the AI-specific security risk that has emerged directly from this shift towards agents. Rather than attacking a system's code, an attacker embeds instructions in content the AI system will read — a webpage, a document, an email — hoping the system will follow the hidden instruction as if it came from its legitimate user or operator.

Example: a webpage or document an AI agent reads contains text instructing it to leak data or take an action

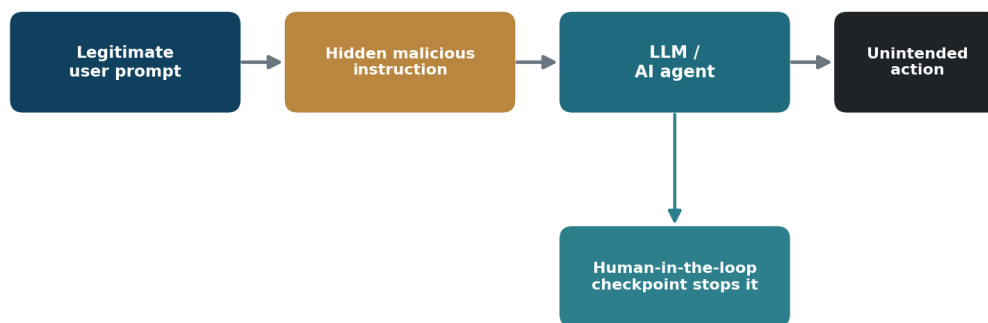


Figure 8.2 — How a prompt injection attack reaches an AI agent, and where a human checkpoint can stop it.

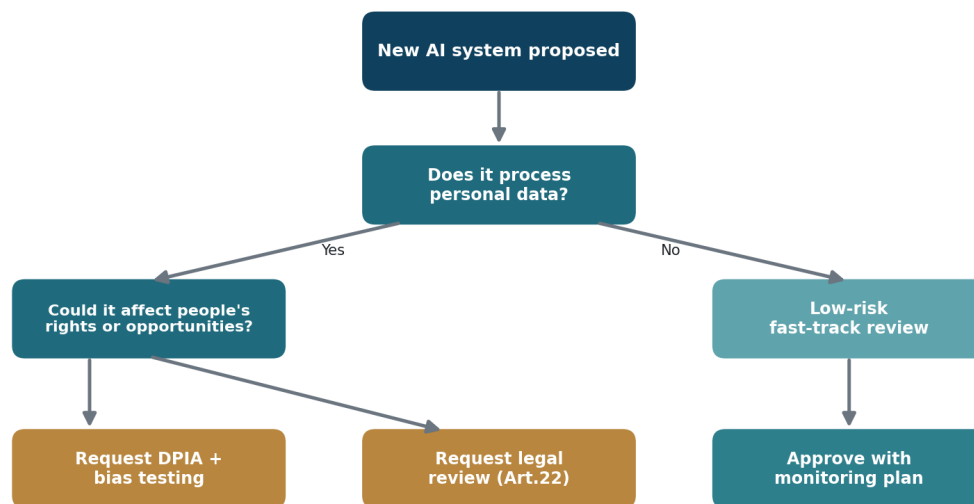
CASE STUDY — THE AIR CANADA CHATBOT RULING

In 2024, a Canadian small claims tribunal ruled against Air Canada after its website chatbot gave a customer incorrect information about the airline's bereavement fare policy, telling him he could apply for a discount retroactively after booking a full-price ticket, when the airline's actual policy did not allow this. Air Canada argued the chatbot was “a separate legal entity responsible for its own actions” and that it should not be held liable for what the tool said.

The tribunal rejected this argument outright, ruling that a company is responsible for all information on its website, whether it comes from a static page or an AI chatbot, and ordered Air Canada to honour the discount and pay damages. The case is now widely cited as establishing that organisations cannot govern by disclaimer: deploying a generative AI tool does not transfer legal responsibility for its output away from the organisation that deployed it.

TRY THIS — YOU ARE THE AI GOVERNANCE LEAD

Scenario: the HR department wants to buy a third-party AI tool that uses a large language model to screen incoming CVs and draft a shortlist recommendation for each vacancy. HR is keen to move fast, since the tool promises to cut screening time by 80%. As AI Governance Lead, do you: (a) approve immediately, given the time savings; (b) reject outright, given the Amazon hiring case from Module 2; (c) request a DPIA before proceeding; (d) request bias testing across protected characteristics before proceeding; (e) request legal review of Article 22 automated decision-making exposure; or some combination? Use the decision tree below to work through it before reading the model answer.



Every branch ends in a documented, named decision — never silence

Figure 8.3 — A decision tree for the AI Governance Lead scenario above.

Model answer: neither (a) nor (b) alone is right. This system almost certainly processes personal data and could affect people's access to employment, so it sits in the high-risk tier from Module 5. The correct combination is (c), (d) and (e) together: a DPIA is very likely mandatory given the scale and impact on individuals (Module 6); bias testing across protected characteristics is essential given the Amazon precedent (Module 2); and legal review is needed to establish whether the tool makes solely automated decisions engaging Article 22, and if so, what human-review safeguard must be built in before launch. Only once all three come back satisfactorily should the system move to approval with an ongoing monitoring plan — exactly the outcome the decision tree's rightmost branch represents.

8.6 ISO/IEC 42001: The AI Management System Standard

Where the NIST AI RMF from Module 5 is voluntary and cannot be certified against, ISO/IEC 42001, published in December 2023, is the first international standard an organisation can be independently audited and certified against for its AI management system, in the same way organisations certify to ISO/IEC 27001 for information security. It follows the same Plan-Do-Check-Act structure as other ISO management system standards, which makes it straightforward to integrate into an organisation that already holds ISO 27001 or ISO 9001 certification.

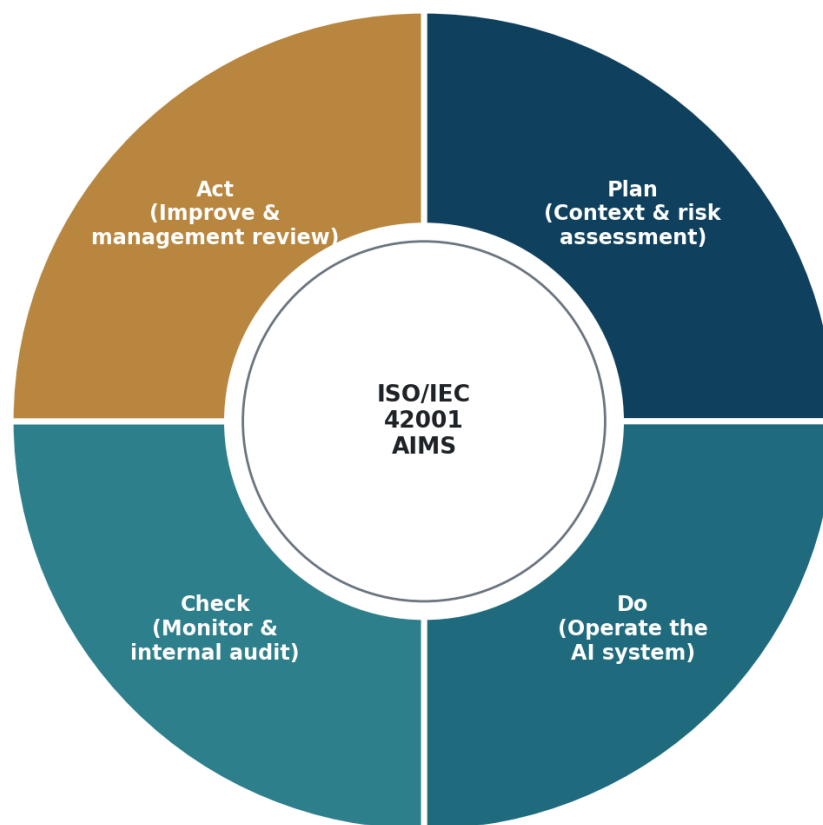


Figure 8.4 — ISO/IEC 42001's Plan-Do-Check-Act structure.

- **Plan** — establish the context, leadership commitment, and a documented AI risk assessment for each system in scope.
- **Do** — operate the AI system in line with the documented controls and objectives set out in the planning stage.

- **Check** — monitor performance, conduct internal audits, and verify that controls are actually operating as documented, not merely as designed.
- **Act** — feed audit findings and incidents into management review, and improve the management system for the next cycle.

UK IN FOCUS

UK organisations increasingly cite ISO/IEC 42001 certification in tenders and client due diligence as evidence of a working AI governance system, in much the same way ISO 27001 is now routinely requested for information security. A recruitment or facilities partner that can point to a client's ISO 42001 status has a fast, credible way to confirm that AI-related contractual and safety obligations are being taken seriously.

KEY TAKEAWAYS

- Generative AI and AI agents introduce risks the rest of this course does not fully cover on its own: hallucination, prompt injection, and autonomous action without a human in the loop.
- The Samsung case shows that ungoverned staff use of public generative AI tools, not a technical failure, is often the actual point of failure.
- The Air Canada ruling establishes that deploying a chatbot or AI agent does not transfer legal responsibility for its output away from the organisation that deployed it.
- Prompt injection is the AI-specific security risk created by agents that act on content they read, and needs its own human-in-the-loop checkpoints and audit trails.
- ISO/IEC 42001 is the certifiable counterpart to the voluntary NIST AI RMF, and is increasingly requested as evidence of AI governance in UK commercial due diligence.

FURTHER READING

- ISO/IEC 42001:2023 — Information technology, Artificial intelligence management system, [iso.org](https://www.iso.org)
- *Moffatt v. Air Canada*, 2024 BCCRT 149 — the Canadian tribunal decision, canlii.org
- OWASP — Top 10 for Large Language Model Applications (prompt injection reference)

MODULE 8 CHECK-IN QUIZ

Five questions to confirm your understanding before moving on. Answers are provided in the Answer Key at the end of the course.

1. What distinguishes an AI agent from a standard large language model interaction?

- A. An agent only produces text for a human to read
- B. An agent can take actions — sending messages, executing purchases, calling other software — rather than only producing output for a human to act on
- C. An agent is always more accurate than a standard model
- D. There is no meaningful difference

2. What was the actual governance failure in the Samsung ChatGPT case?

- A. A technical fault in ChatGPT itself
- B. The absence of a policy or approved alternative telling staff what was acceptable to paste into a public AI tool
- C. Samsung's own servers being hacked
- D. A failure of South Korean data protection law

3. What did the Air Canada tribunal ruling establish?

- A. Chatbots are separate legal entities not liable for their own statements
- B. A company remains responsible for information provided by its own chatbot, the same as for any other part of its website
- C. Airlines are exempt from consumer protection law for AI tools
- D. Customers cannot rely on chatbot statements under any circumstances

4. Prompt injection is best described as:

- A. A method for improving model accuracy
- B. An attack that embeds hidden instructions in content an AI system reads, hoping the system follows them as if from its legitimate user
- C. A type of hallucination
- D. A UK GDPR lawful basis

5. What is the key difference between the NIST AI RMF and ISO/IEC 42001?

- A. They cover completely unrelated topics
- B. NIST AI RMF is voluntary and non-certifiable; ISO/IEC 42001 is a certifiable management system standard an organisation can be independently audited against
- C. ISO/IEC 42001 only applies to US organisations
- D. NIST AI RMF replaced ISO/IEC 42001 in 2023